

W12D4 - Analisi delle vulnerabilità e azioni di rimedio

Corso Cybersecurity

Ignazio Guttadauro

1. Introduzione

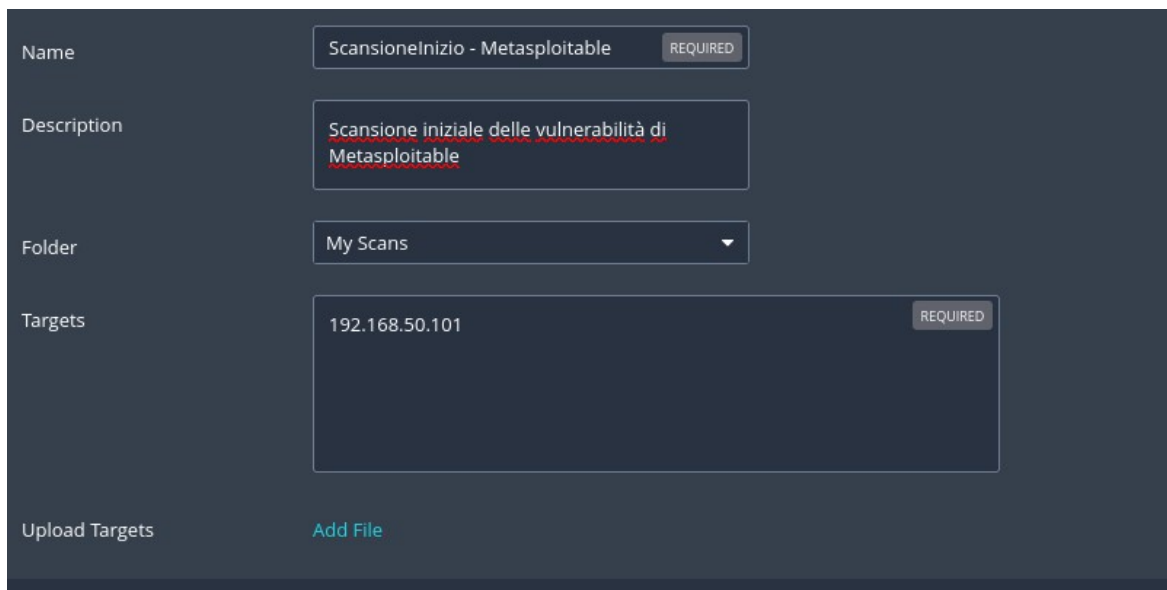
In questo esercizio ho eseguito una scansione completa delle vulnerabilità presenti sulla macchina Metasploitable con indirizzo 192.168.50.101. Per la scansione ho utilizzato Nessus con il template Basic Network Scan e CVSS v3.0. Dopo aver controllato i risultati, ho scelto tre vulnerabilità critiche sulle quali intervenire.

Le vulnerabilità che ho scelto sono state la password debole del servizio VNC, una bind shell aperta sulla porta 1524 e la vulnerabilità Ghostcat relativa al connettore AJP di Apache Tomcat. Per ognuna ho prima verificato il problema, poi ho applicato la modifica necessaria e infine ho controllato il risultato. Al termine ho ripetuto la scansione con Nessus per confrontarla con quella iniziale.

2. 1. Scansione iniziale

1.1 Configurazione e obiettivo della scansione

Come prima cosa ho configurato la scansione sul target Metasploitable 192.168.50.101. Questa prima scansione mi è servita per vedere quali vulnerabilità erano presenti prima di effettuare qualsiasi modifica.



The screenshot shows the Nessus configuration interface for a new scan. The fields are as follows:

- Name:** ScansioneInizio - Metasploitable (with a REQUIRED tag)
- Description:** Scansione iniziale delle vulnerabilità di Metasploitable
- Folder:** My Scans (dropdown menu)
- Targets:** 192.168.50.101 (with a REQUIRED tag)
- Upload Targets:** Add File (button)

Figura 1 - Configurazione della scansione iniziale sul target 192.168.50.101.

1.2 Risultati generali

Al termine della prima scansione Nessus ha mostrato 64 voci nella sezione Vulnerabilities. I risultati comprendevano 9 Critical, 5 High, 22 Medium, 8 Low e 129 Informational. Per l'esercizio mi sono concentrato sulle vulnerabilità Critical e ne ho scelte tre da correggere.



Figura 2 - Riepilogo della scansione iniziale Nessus.

Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (8.04.x)	General	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	

Figura 3 - Elenco delle principali vulnerabilità Critical rilevate inizialmente.

1.3 Vulnerabilità critiche selezionate

1.3.1 VNC Server 'password' Password - CVSS 10.0

La prima vulnerabilità scelta riguarda il servizio VNC sulla porta TCP 5900. Nessus è riuscito ad autenticarsi usando la password predefinita "password". Questo significa che il servizio era protetto da una credenziale troppo semplice e facilmente utilizzabile per ottenere accesso remoto al desktop.

Figura 4 - Dettaglio Nessus della vulnerabilità VNC con password debole.

1.3.2 Bind Shell Backdoor Detection - CVSS 9.8

La seconda vulnerabilità era presente sulla porta TCP 1524. Nessus ha rilevato una shell raggiungibile senza autenticazione e, durante il controllo, è riuscito a eseguire il comando id ottenendo uid=0(root) e gid=0(root). In pratica la shell permetteva di eseguire comandi direttamente con privilegi di root.

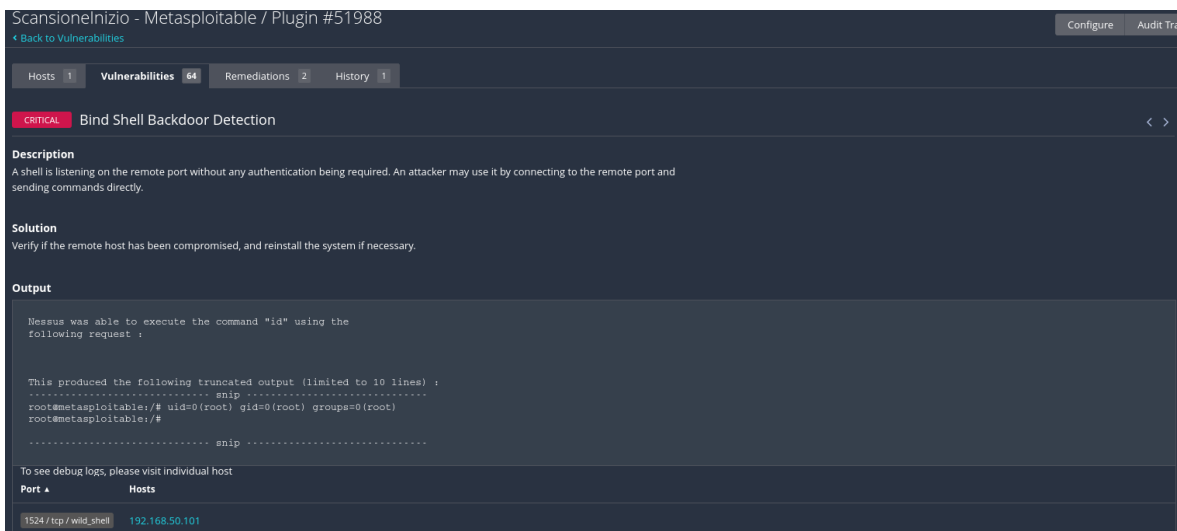


Figura 5 - Nessus rileva la bind shell e l'esecuzione di comandi come root.

1.3.3 Apache Tomcat AJP Connector Request Injection (Ghostcat) - CVSS 9.8

La terza vulnerabilità scelta è Ghostcat, rilevata da Nessus sul connettore AJP di Apache Tomcat. Il servizio AJP era esposto e la vulnerabilità poteva permettere l'accesso a file dell'applicazione e, in alcune configurazioni, portare ad attacchi più gravi.

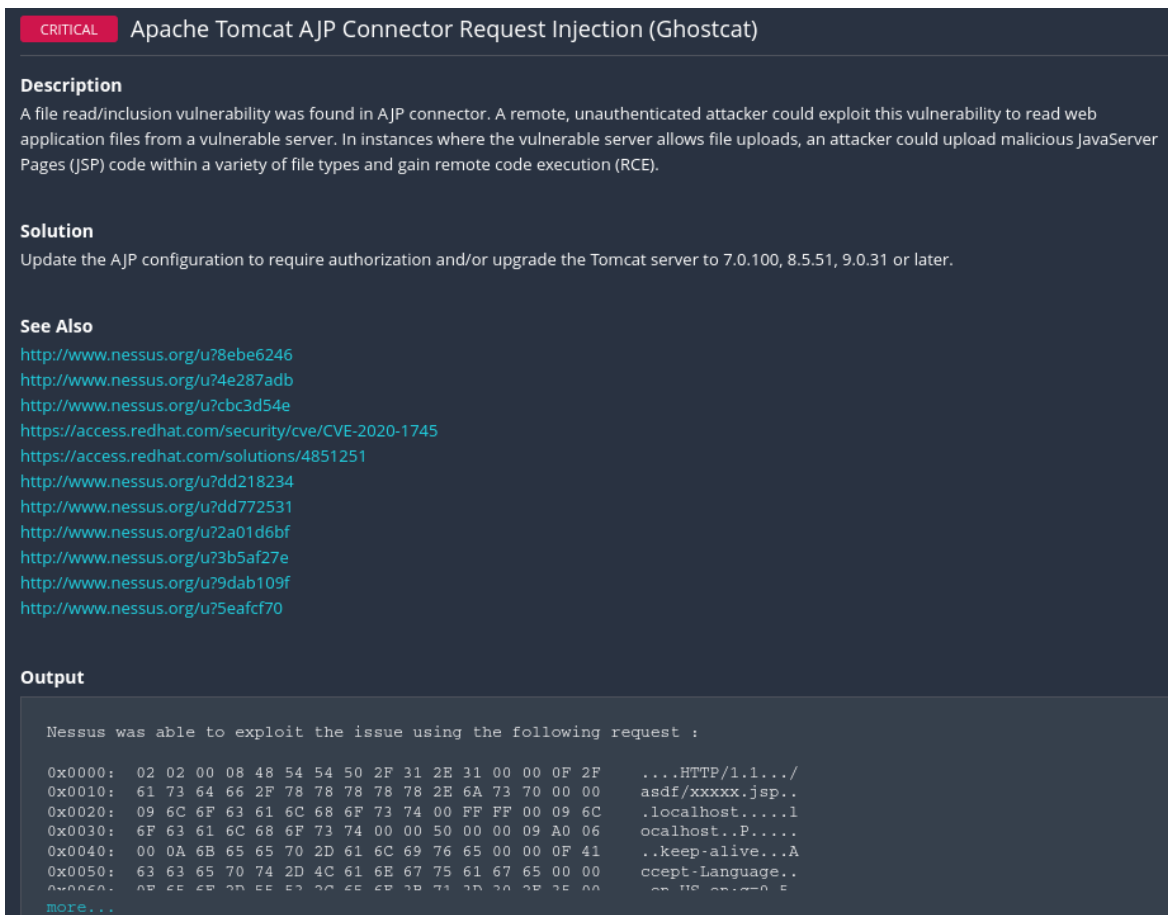


Figura 6 - Dettaglio Nessus della vulnerabilità Ghostcat.

3. 2. Azioni di remediation

2.1 Remediation della password VNC

Per correggere il problema VNC ho controllato quale file delle password veniva realmente utilizzato dal processo Xtightvnc. Il servizio in ascolto sulla porta 5900 utilizzava /root/.vnc/passwd. Ho quindi cambiato la password con il comando vncpasswd impostandone una più robusta. La nuova password non viene riportata nel report.

```
Last login: Sun Oct 4 07:52:39 2020
msfadmin@metasploitable:~$ sudo cat /proc/4554/cmdline | tr '\0' ' '
[sudo] password for msfadmin:
x11tightvnc -id -desktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -rfbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fonts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/share/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co /etc/X11/rgb
msfadmin@metasploitable:~$ sudo vncpasswd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$
```

Figura 7 - Aggiornamento del file password effettivamente utilizzato dal servizio VNC.

Dopo la modifica ho provato a collegarmi da Kali con vncviewer. Utilizzando la vecchia password "password" ho ricevuto il messaggio Authentication failure. Ripetendo il collegamento con la nuova password l'autenticazione è invece riuscita. In questo modo ho verificato che la vecchia credenziale non era più valida e che il servizio VNC continuava a funzionare.

```
(kali@kali)-[~]
$ which vncviewer
/usr/bin/vncviewer

(kali@kali)-[~]
$ vncviewer 192.168.50.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure
Warning: Permanently added '192.168.50.101' (RSA) to
this session may be vulnerable to 'store now, decrypt
later' attack. See https://openbsd.org/vnc/8.3/
```

Figura 8 - La vecchia password VNC viene rifiutata.

```
(kali@kali)-[~]
$ vncviewer 192.168.50.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0

TightVNC: root's X desktop (metasploitable:0)
root@metasploitable: /
```

Figura 9 - Autenticazione VNC riuscita con la nuova password.

2.2 Remediation della bind shell sulla porta 1524

Per capire da dove proveniva la shell sulla porta 1524 ho cercato la relativa configurazione nel sistema. Nel file `/etc/inetd.conf` ho trovato la voce `ingreslock` configurata per avviare `/bin/bash` come root. Prima di modificarla ho creato una copia di backup del file, poi ho commentato la riga e riavviato `xinetd` per applicare la modifica.

```
msfadmin@metasploitable:~$ sudo grep -R "ingreslock\\|1524" /etc 2>/dev/null
/etc/services:ingreslock      1524/tcp
/etc/services:ingreslock      1524/udp
/etc/inetd.conf:ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$
```

Figura 10 - Individuazione della configurazione `ingreslock` che avviava `/bin/bash` come root.

```
msfadmin@metasploitable:~$ sudo cp /etc/inetd.conf /etc/inetd.conf.bak
msfadmin@metasploitable:~$ sudo sed -i '/^ingreslock /s/^/#/' /etc/inetd.conf
msfadmin@metasploitable:~$ grep ingreslock /etc/inetd.conf
#ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$
```

Figura 11 - Disabilitazione della voce `ingreslock` in `/etc/inetd.conf`.

Dopo il riavvio ho controllato nuovamente la porta 1524 e non risultava più in ascolto. Ho fatto anche una prova da Kali con `netcat` e la connessione è stata rifiutata. La `bind shell` quindi non era più raggiungibile dalla rete.

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nc -nv 192.168.50.101 1524
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) : Connection refused
msfadmin@192.168.50.101's password:
┌──(kali㉿kali)-[~]
└─$
```

Figura 12 - Verifica da Kali: connessione alla porta 1524 rifiutata.

2.3 Remediation Ghostcat / AJP 8009

Per `Ghostcat` ho verificato la configurazione di `Tomcat` e ho trovato il connettore `AJP/1.3` attivo sulla porta 8009 nel file `/etc/tomcat5.5/server.xml`. Dal momento che per il laboratorio non avevo bisogno di questo connettore, ho deciso di disabilitarlo. Prima ho creato una copia di backup di `server.xml`, poi ho commentato il `Connector` relativo alla porta 8009 e riavviato `Tomcat 5.5`.

```
msfadmin@metasploitable:~$ sudo grep -n -B 2 -A 3 '8009' /etc/tomcat5.5/server.xml
102-  →
103-  →
104:  <!-- Define an AJP 1.3 Connector on port 8009 -->
105:  <Connector port="8009"
106:             enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
107-  →
108:  <!-- Define a Proxied HTTP/1.1 Connector on port 8082 -->
msfadmin@metasploitable:~$
```

Figura 13 - Configurazione `AJP/1.3` attiva sulla porta 8009 prima della remediation.

```

msfadmin@metasploitable:~$ sudo sed -n '102,109p' /etc/tomcat5.5/server.xml
→
<!-- Define an AJP 1.3 Connector on port 8009 -->
<!--
  <Connector port="8009"
    enableLookups="false" redirectPort="8443" protocol="AJP/1.3" /> -->

<!-- Define a Proxied HTTP/1.1 Connector on port 8082 -->
<!-- See proxy documentation for more information about using this. -->
msfadmin@metasploitable:~$

```

Figura 14 - Connector AJP disabilitato nel file server.xml.

Dopo il riavvio ho controllato che la porta 8009 non fosse più in ascolto. Per sicurezza ho effettuato anche un test da Kali con netcat: il risultato è stato Connection refused. Il connettore AJP quindi non era più esposto sulla rete.

```

Session Actions Edit View Help
(kali@kali)-[~]
$ nc -nv 192.168.50.101 8009
(UNKNOWN) [192.168.50.101] 8009 (?): Connection refused
msfadmin@metasploitable:~$ sudo cp /etc/inetd.conf /etc/inetd.conf.bak
(kali@kali)-[~]
$ sudo sed -i 's/^ingreslock /s/^/#/' /etc/inetd.conf
msfadmin@metasploitable:~$ grep ingreslock /etc/inetd.conf
#ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$ sudo /etc/init.d/openbsd-inetd restart
msfadmin@metasploitable:~$ sudo netstat -tuln | grep 1524

```

Figura 15 - Verifica da Kali: connessione alla porta 8009 rifiutata.

4. 3. Scansione finale e verifica

3.1 Nuova scansione Nessus

Dopo aver completato le tre modifiche ho eseguito una nuova Basic Network Scan con Nessus sullo stesso target 192.168.50.101. In questo modo ho potuto confrontare direttamente il risultato finale con quello ottenuto prima delle correzioni.

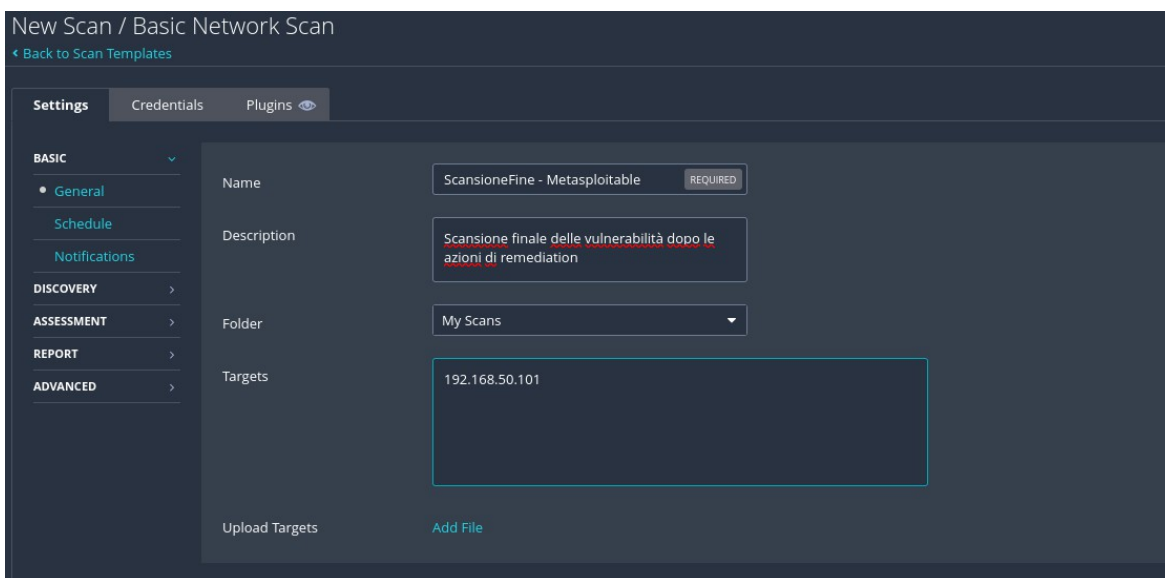


Figura 16 - Configurazione della scansione finale sul medesimo target.

3.2 Risultati finali

Nella scansione finale le voci presenti nella sezione Vulnerabilities sono scese da 64 a 61. Le vulnerabilità Critical sono passate da 9 a 6, mentre sono rimaste 5 High, 22 Medium e 8 Low; le Informational sono passate da 129 a 127. Soprattutto, le tre vulnerabilità sulle quali ero intervenuto non comparivano più tra i risultati.



Figura 17 - Riepilogo della scansione finale Nessus.

Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
HIGH	7.5			NFS Shares World Readable	RPC	1	
HIGH	7.5			Samba Badlock Vulnerability	General	1	
MIXED	...	...	...	SSL (Multiple Issues)	General	28	
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	
MEDIUM	5.9			SSL Anonymous Cipher Suites Supported	Service detection	1	
MEDIUM	5.9			SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)	Misc.	1	
MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6	
MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	3	
MIXED	...	...	...	SMB (Multiple Issues)	Misc.	2	
MIXED	...	...	...	TLS (Multiple Issues)	Misc.	2	

Figura 18 - Elenco finale: assenza dei tre finding trattati.

3.3 Confronto prima/dopo

Severità / indicatore	Prima	Dopo	Variazione
Critical	9	6	-3
High	5	5	0
Medium	22	22	0
Low	8	8	0
Informational	129	127	-2
Voci Vulnerabilities	64	61	-3

Confrontando le due scansioni, le vulnerabilità Critical sono diminuite da 9 a 6. La differenza è quindi di tre vulnerabilità, lo stesso numero di quelle che ho corretto durante l'esercizio. Sul sistema rimangono comunque altre vulnerabilità, perché Metasploitable è una macchina volutamente vulnerabile e in questa attività mi sono occupato solo dei tre problemi scelti.

3.4 Verifica delle vulnerabilità trattate

Vulnerabilità	Stato iniziale	Intervento	Esito finale
---------------	----------------	------------	--------------

VNC Server 'password' Password	Critical 10.0	Sostituzione password VNC debole	Finding non più presente
Bind Shell Backdoor Detection	Critical 9.8	Disabilitazione ingreslock / porta 1524	Finding non più presente
Ghostcat - AJP Connector	Critical 9.8	Disabilitazione AJP / porta 8009	Finding non più presente

5. Conclusioni

Al termine dell'esercizio ho verificato che le tre modifiche effettuate avessero realmente risolto i problemi scelti. I controlli manuali hanno mostrato che la vecchia password VNC non funzionava più e che le porte 1524 e 8009 non erano più raggiungibili. La scansione finale di Nessus ha poi confermato il risultato: le vulnerabilità Critical sono passate da 9 a 6 e i tre finding trattati non erano più presenti. Rimangono altre vulnerabilità sulla macchina Metasploitable, ma non facevano parte degli interventi scelti per questa esercitazione.

Fine esercizio: 05/10/2026 - ore 06:35